

IsoTech Ink: Governance Compliance Gap Assessment

Overview

This Governance Compliance Gap Assessment was conducted as part of the IsoTech Ink Enterprise Cybersecurity Governance & Risk Transformation Initiative.

The purpose of this assessment is to evaluate the organization's current cybersecurity governance posture against desired future-state capabilities aligned with recognized industry frameworks and security best practices.

The assessment identifies gaps in governance, monitoring, access management, incident response, vendor oversight, and employee awareness while providing actionable recommendations designed to improve organizational security maturity.

The recommendations contained within this report support strategic cybersecurity planning, compliance readiness, risk reduction, and executive decision-making.

Full Governance Gap Assessment Table

Full Governance Gap Assessment Table (IsoTech Ink)					
Area	Current State	Desired State	Gap Identified	Risk Level	Recommendation
Multi-Factor Authentication	MFA only used by executives	MFA required for all employees	Incomplete deployment	High	Implement organization-wide MFA
Access Governance	Access reviews performed inconsistently	Quarterly access reviews	Lack of standardized review process	High	Formalize RBAC review procedures
Remote Access Security	Hybrid workers use varying access methods	Standardized secure remote access	Inconsistent controls	High	Implement VPN and conditional access requirements
Security Awareness	Informal awareness activities	Quarterly training and phishing simulations	Inconsistent employee education	High	Launch structured awareness program
Phishing Reporting	No formal reporting process	Centralized phishing reporting workflow	Low employee reporting visibility	High	Create phishing reporting procedures

Vendor Risk Management	Vendors not formally assessed	Annual vendor security reviews	No third-party oversight process	High	Implement vendor risk management program
Vendor Classification	Vendors treated equally	Risk-based vendor classification	Lack of prioritization	Medium	Establish vendor tiering model
Logging Visibility	Limited system logging	Centralized log collection	Monitoring gaps	High	Expand SIEM log ingestion
SIEM Monitoring	Limited alert coverage	Comprehensive alert monitoring	Detection blind spots	High	Develop monitoring use cases
DNS Monitoring	No DNS visibility	Continuous DNS monitoring	Lack of network visibility	Medium	Implement DNS monitoring dashboards
Brute Force Detection	No dedicated detections	Automated brute force alerts	Delayed detection capability	High	Develop brute force detection rules
Incident Response Planning	Basic IR documentation	Fully tested IR program	Limited operational readiness	High	Expand IR procedures
Tabletop Exercises	No exercises conducted	Annual exercises	Untested response process	Medium	Conduct tabletop exercises
Governance Reporting	Ad hoc reporting	Monthly executive reporting	Limited executive visibility	Medium	Establish governance reporting cadence
KPI Management	Metrics not formally tracked	Security KPI dashboard	Lack of measurable outcomes	Medium	Implement KPI scorecards
Policy Governance	Policies reviewed inconsistently	Annual review process	Policy maintenance gaps	Medium	Establish policy governance cycle
Data Protection	Partial encryption coverage	Full encryption coverage	Data protection inconsistency	High	Expand encryption controls
Endpoint Visibility	Limited endpoint monitoring	Comprehensive endpoint telemetry	Detection limitations	Medium	Deploy endpoint monitoring strategy
Compliance Mapping	No framework alignment	Mapped security controls	Limited compliance visibility	Medium	Maintain compliance mapping matrix
Security Governance Structure	Informal governance ownership	Formal governance committee	Accountability gaps	Medium	Establish cybersecurity steering committee

[*link to the Spreadsheet](#)